📜 CISSP-ISSEP Master Publication Reference 📚

🔑 Core RMF / Security Engineering	🏛️ DoD / National Guidance
NIST SP 800-37	DoDI 8510.01
NIST SP 800-53	CNSSI 1253
NIST SP 800-160	JSIG
NIST SP 800-161	DAAPM
ISO/IEC 15408	DoDM 5205.07
CEM 2022	DoD CIO Library
INCOSE SE Handbook	The PM's JSIG/RMF Handbook
(ISC)² ISSEP CBK	

📊 Risk & Contingency Standards	🛠️ Engineering / Architecture Standards
FIPS 199	ISO/IEC/IEEE 15288
FIPS 200	ISO/IEC/IEEE 42010
NIST SP 800-60	NSA IATF
NIST SP 800-39	
NIST SP 800-30	CDSE ISSM/ISSO Toolkits
NIST SP 800-34	
NIST SP 800-137 (+137A)	DISA STIGs & SCAP
NIST SP 800-115	

📝 DoD Cybersecurity Policies	🤖 SCAP & Automation	⚖️ Laws & Mandates
DoDI 8500.01	NIST SP 800-126	NIST SP 800-53
DoDI 8510.01	NIST SP 800-117	CNSSI 1253
DISA STIG Checklists	NIST IR 7511	
DAAPM	NIST SCAP Repositories	FISMA (44 USC §3541)
JSIG		

CISSP-ISSEP Master Publication Reference

Core ISSEP / "Must Know"	
NIST SP 800-37 Rev.2	The **NIST RMF** for Information Systems & Organizations.
NIST SP 800-53 Rev.5	Security & Privacy Controls. (**RMF Security Control Families**) (**800-53B for Baselines** & **800-53A for Assessments**)
NIST SP 800-160 Vol.1	Systems Security Engineering Principles & Considerations
NIST SP 800-161 Rev.1	Cybersecurity Supply Chain Risk Management (C-SCRM)
ISO/IEC 15408	The Common Criteria Security Assurance Framework
↑ CEM 2022 ↑	↑ Common Criteria Evaluation Methodology ↑
INCOSE Systems Engineering Handbook	Guidance for systems engineering best practices.
Official (ISC)² Guide to the CISSP-ISSEP CBK	Official ISC2 ISSEP Resource to be used as a reference for systems security engineering (ISSEP) concepts.

DoD / NSS Overlays & SAP-specific	
DoDI 8510.01	The **DoD-specific** RMF policy
CNSSI 1253	**Categorization & control selection** for National Security Systems **(NSS)**
JSIG	Joint SAP Implementation Guide - **SAP Programs**
DAAPM	DCSA Assessment & Authorization Process Manual - **Collateral Programs**
DoDM 5205.07	**The SAP Security Manual -** Cyber sections that reference JSIG/RMF
DoD CIO Library	Quick References + Helpful **RMF memos** / **Continuous ATO**
PM's JSIG/RMF Handbook	DCSA's helpful **orientation for SAP PM/ISSO interfaces**

RMF Companion / Governance & Risk (high-yield for ISSEP)	
FIPS 199	**Security Categorization** — Defines security impact levels for systems.
FIPS 200	**Minimum Security Requirements** — Baseline security for federal systems.
NIST SP 800-60 Vol.1/2	Maps information types to security impact levels.
NIST SP 800-39	Tiered risk management framework guidance.
NIST SP 800-30 Rev.1	Guidelines for conducting risk assessments.
NIST SP 800-34 Rev.1	Contingency planning for federal systems.
NIST SP 800-137 (+137A)	Continuous monitoring **(CONMON) strategy and assessments.**
NIST SP 800-115	Technical **security testing and assessment methods.**

CISSP-ISSEP Master Publication Reference

Systems Engineering Standards (tie-ins with 800-160)	
ISO/IEC/IEEE 15288	**System life cycle processes**—NIST 800-160 Vol.1 explicitly complements 15288
ISO/IEC/IEEE 42010	**Architecture description**—viewpoints, stakeholders, AD structure
INCOSE Systems Engineering Handbook	Guidance for systems engineering best practices. Broader Scope with Various System Types in the Focus for this resource, Core Tenants should be observed.

Practical SAP/ISSO Aids (Training / References)	
NSA Information Assurance Technical Framework (IATF)	**Defines IA strategy, layered defenses, and risk-based approaches for U.S. national security systems.** **(Related to NIST SP 800-160, 30, 39, 37, 53, CNSSI 1253, and ISO 15403)**
CDSE ISSM/ISSO Toolkits & SAP Job Aids	**DoD guides for security management responsibilities.**
DISA STIGs & SCAP Benchmarks	**Configuration standards and automated compliance checks.**

STIGs & SCAP Related Publications		
STIG	**DoDI 8500.01**	*Cybersecurity* (**overarching DoD cybersecurity policy**)
	DoDI 8510.01	*MF for DoD IT* (**DoD-specific RMF**, links STIG compliance to authorization).
	DISA STIG Checklists	The actual configuration guides (OS, DB, apps, network devices, etc.).
	The DAAPM	Enclave/collateral guidance (STIG enforcement context).
	The JSIG	SAP overlay (STIG enforcement in SAPs).
SCAP	**NIST SP 800-126 Rev.3**	*SCAP Specification* (defines SCAP components: XCCDF, OVAL, CPE, etc.).
	NIST SP 800-117	*Guide to Adopting SCAP* (how organizations should use SCAP).
	NIST IR 7511	*SCAP Content Validation* (checklists, content testing).
	NIST SCAP Content Repos.	Official benchmark storage (e.g., NVD hosts SCAP content).
LINKS	**NIST SP 800-53**	Security & Privacy Controls (**STIGs map to these**).
	CNSSI 1253	Security categorization & control selection (**STIGs help enforce**).
	FISMA **(44 U.S.C. § 3541, etc.)**	Mandates use of NIST standards and SCAP in federal systems.

STIG & SCAP TLDR

- **NIST** publishes the **SCAP standard/specs (800-126, 800-117, IR 7511).**
- **DISA** publishes the **STIGs (with checklists that can be run as SCAP benchmarks).**
- **DoD directives (8500.01, 8510.01, DAAPM, JSIG) make their use mandatory.**

ISSEP-Relevant Publication and Resource "Family" Mental Mapping Guide

Core RMF Spine

"The backbone publications that define the RMF lifecycle and its variants."

- NIST SP 800-37 (RMF)
- DoDI 8510.01 (DoD RMF)
- CNSSI 1253 (DoD/IC controls)
- JSIG (SAP RMF overlay)
- DAAPM (IC SAP RMF overlay)
- PM's JSIG/RMF Handbook

DoD & National Guidance

"Directives, handbooks, and top-level guidance outside the pure RMF documents"

- DoD CIO Library
- DoDI 8500.01 (Cybersecurity)
- CDSE ISSM/ISSO Toolkits
- NSA IATF (Defense-focused IA guidance)

Risk & Contingency Standards

"Risk frameworks, assessments, incident & continuity planning."

- NIST SP 800-39
- NIST SP 800-30
- NIST SP 800-34
- NIST SP 800-137 / 137A
- NIST SP 800-115

Engineering & Architecture Standards

"Systems engineering, security engineering, and design-focused publications"

- NIST SP 800-160 Vol. 1 & Vol. 2
- NIST SP 800-161
- ISO/IEC/IEEE 15288 & 42010
- INCOSE SE Handbook
- ISO/IEC 15408 + CEM

DoD Cybersecurity Policies

"Technical enforcement standards, STIGs, and assessment methods."

- DISA STIGs & Checklists
- SCAP Repositories / NIST IR 7511
- NIST SP 800-126 (SCAP)
- NIST SP 800-117 (SCAP tools)

SCAP & SOAR

"Automation and machine-driven compliance/security."

- SCAP as a framework (linked to 126/117/7511 above)
- SOAR tools

Laws & Mandates

"Statutory and top-level legal authority that drives everything else."

- FISMA (44 USC §3541)
- FIPS 199
- FIPS 200
- NIST SP 800-60 (Info Types/Categorization mapping)

ISSEP CBK

NSA-co-developed framework and exam reference for engineering secure government systems.

Core RMF Spine

Purpose

Defines the Risk Management Framework (RMF) for federal information systems. Integrates security and privacy into the system life cycle and provides a structured process for risk-based decision making.

Core Concepts

- Seven RMF Steps → Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor
- Rev. 2 enhancements → added Prepare step, explicit privacy integration, supply chain risk mgmt (SCRM), and reuse of common controls
- Applies at both organizational and system levels

ISSEP Takeaways

- Be able to list the 7 steps in order
- Understand key roles → AO, ISSO, ISSE, PM, Assessors
- Know which pubs tie into each step (e.g., FIPS 199/200 for Categorize, SP 800-53 for Select, SP 800-53A for Assess, SP 800-137 for Monitor)
- Privacy and SCRM are required considerations
- Common vs system controls → authorizations can be inherited

Crosslinks

- CNSSI 1253 → DoD/IC overlay for control selection
- DoDI 8510.01, JSIG, DAAPM → DoD RMF implementations
- SP 800-53 → provides the control catalog
- SP 800-39 & 30 → underpin risk management and assessment
- SP 800-160 & ISO/IEC/IEEE 15288 → tie RMF into system engineering

✅ Exam Lens

Expect questions on:

- The 7 RMF steps in order
- What *Prepare* added in Rev. 2
- Roles & responsibilities (Appendix D)
- How RMF maps to FISMA, SP 800-53, CNSSI 1253
- Integration of privacy + SCRM

Core RMF Spine

Purpose

Provides a comprehensive catalog of security and privacy controls for federal systems. Supports RMF by enabling selection, tailoring, and implementation of controls to manage organizational risk under FISMA.

Core Concepts

- 20 Control Families → AC, AT, AU, CA, CM, CP, IA, IR, MA, MP, PE, PL, PM, PS, PT, RA, SA, SC, SI, SR
- Control Structure → Base Control, Control Enhancements, Supplemental Guidance
- Implementation Approaches → System-specific, Common, Hybrid controls
- Baselines → Low, Moderate, High impact; subject to tailoring
- Rev. 5 Integration → Explicit inclusion of privacy controls + Supply Chain Risk Mgmt (SR family)

ISSEP Takeaways

- Recognize the 20 families by name/abbreviation and general scope
- Understand baseline selection and tailoring process
- Know the difference between system-specific, common, hybrid controls
- Connect control use across RMF → Select, Implement, Assess, Monitor
- Identify trustworthiness and assurance concepts (evidence, assessment depth)

Crosslinks

- SP 800-37 → 53 supports Select, Implement, Assess, Monitor steps
- CNSSI 1253 → overlays and adapts controls for DoD/IC
- FIPS 199/200 + SP 800-60 → drive categorization → baseline selection
- SP 800-53A → defines assessment procedures for each control
- SP 800-39 & 30 → provide risk mgmt/assessment context

✅ Exam Lens

Expect questions on:

- The 20 control families and their focus
- Baseline creation (Low/Mod/High) and tailoring rules
- Common vs hybrid vs system-specific controls
- Control structure (base, enhancements, guidance)
- Integration of privacy and supply chain controls in Rev. 5

Core RMF Spine

Purpose

Establishes the DoD implementation of the RMF for all DoD IT, including National Security Systems (NSS). Replaces DIACAP, aligns DoD cybersecurity processes with NIST RMF (SP 800-37), and defines roles, responsibilities, and governance for system authorization.

Core Concepts

- Direct adoption of the 7 RMF Steps → Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor
- Defines DoD Authorizing Officials (AOs), Risk Executive, ISSM/ISSO, and security control assessors
- Establishes the DoD RMF Knowledge Service (RMF KS) as central resource for guidance, templates, controls, overlays
- Enforces use of CNSSI 1253 for categorization/control overlays
- Applies to all DoD IT, including weapons systems, platforms, PIT, and cloud services

ISSEP Takeaways

- DoDI 8510.01 is the policy directive that makes RMF mandatory for DoD IT
- Know DoD-specific roles (Risk Executive Function, AO, SCA, ISSM, ISSO)
- RMF KS is the official DoD knowledge portal for procedures and artifacts
- Authorization decisions are risk-based and must align with mission/business needs
- DoDI 8500.01 (Cybersecurity) works in tandem with 8510.01 to set requirements + RMF execution

Crosslinks

- NIST SP 800-37 → framework source
- CNSSI 1253 → overlays DoD security categorization/control selection
- JSIG, DAAPM → tailored implementations for SAP/IC environments
- DoDI 8500.01 → overarching DoD cybersecurity policy that 8510.01 enforces

✅ Exam Lens

Expect questions on:

- DoDI 8510.01 = DoD RMF policy (replaced DIACAP)
- Key DoD roles (AO, SCA, ISSM, ISSO, Risk Executive)
- Purpose of RMF Knowledge Service (RMF KS)
- Relationship to CNSSI 1253 and 8500.01
- Applicability to all DoD IT, including NSS and PIT

Core RMF Spine

Purpose

Implements FIPS 199/200 and NIST SP 800-53 specifically for National Security Systems (NSS). Provides guidance on categorization and control selection for DoD and Intelligence Community systems, ensuring consistent overlays for confidentiality, integrity, and availability requirements.

Core Concepts

- Establishes security categorization overlays for NSS → tailors NIST SP 800-53 baselines
- Defines mapping of impact levels (Low/Moderate/High) to DoD/IC mission needs
- Provides structured approach for applying DoD-specific and IC-specific requirements to RMF control selection
- Uses Overlays to adjust control baselines for specialized environments (e.g., SAP, SCI, weapons systems)
- Ensures categorization/control selection is consistent across DoD and IC programs

ISSEP Takeaways

- CNSSI 1253 = bridge doc between NIST standards (FIPS 199/200, SP 800-53) and DoD/IC systems
- You must understand that impact categorization drives control baseline selection
- Overlays allow tailoring for mission-specific requirements while maintaining consistency
- Mandatory for National Security Systems under DoD RMF (DoDI 8510.01)
- Control families remain those of SP 800-53, but application differs due to NSS mission context

Crosslinks

- FIPS 199/200 + SP 800-60 → initial categorization rules
- SP 800-53 → control catalog; 1253 provides the NSS overlays
- DoDI 8510.01 → requires CNSSI 1253 use in DoD RMF
- JSIG / DAAPM → apply 1253 overlays in SAP/IC environments

✅ Exam Lens

Expect questions on:

- CNSSI 1253 = DoD/IC categorization & overlay guidance
- Relationship to FIPS 199/200 and SP 800-53
- How overlays are used to tailor control selection
- Applicability to National Security Systems (NSS)
- Linkage to DoDI 8510.01 RMF policy

Core RMF Spine

Purpose

Defines how the Risk Management Framework (RMF) is applied to DoD Special Access Programs (SAPs). Provides additional security guidance and overlays for SAP environments while remaining aligned with NIST SP 800-37, CNSSI 1253, and DoDI 8510.01.

Core Concepts

- Implements the 7 RMF steps with SAP-specific tailoring
- Requires use of CNSSI 1253 overlays for categorization and control selection
- Adds guidance for SAP authorization boundaries, cross-domain solutions, and classified information handling
- Emphasizes continuous monitoring and SAP-unique risk tolerance levels
- Integrates eMASS (Enterprise Mission Assurance Support Service) for artifacts and ATO packages

ISSEP Takeaways

- JSIG = RMF playbook for Special Access Programs
- Builds directly on NIST RMF but adds overlays for classified, compartmented systems
- Key AO = Program Executive/PM under SAP authority
- ISSOs/ISSEs must ensure compliance with NSS controls + SAP unique requirements
- Strong emphasis on authorization packages, monitoring, and reporting in highly controlled environments

Crosslinks

- NIST SP 800-37 → base RMF process
- CNSSI 1253 → categorization & control overlays required for NSS/SAP systems
- DoDI 8510.01 → mandates RMF adoption across DoD, JSIG applies it to SAPs
- DAAPM → IC/SAP counterpart to JSIG; used in DNI/IC SAP environments

✅ Exam Lens

Expect questions on:

- JSIG = SAP implementation of RMF
- Use of CNSSI 1253 overlays in SAPs
- How JSIG differs from “vanilla” RMF (added security for SAPs)
- ATO/continuous monitoring expectations in SAP programs
- Relationship between JSIG, 8510.01, and DAAPM

Core RMF Spine

Purpose

Serves as a practical guide for Program Managers (PMs) executing RMF and JSIG requirements in SAP environments. Translates policy into day-to-day management actions, clarifying how PMs should integrate security into program planning, system development, and authorization.

Core Concepts

- PM Role in RMF → responsible for ensuring RMF tasks are resourced, tracked, and completed
- RMF Steps → overview of PM responsibilities at Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor
- Artifacts & Deliverables → guidance on managing eMASS inputs, POA&Ms, SSPs, and Continuous Monitoring plans
- Integration with JSIG → SAP-specific tailoring and overlays explained in PM terms
- Communication → PM as liaison between AO, ISSO/ISSM, ISSE, contractors, and mission stakeholders

ISSEP Takeaways

- This handbook = bridge between RMF/JSIG policy and PM execution
- Expectations: resource allocation, milestone tracking, and risk communication
- PM must ensure artifacts (SSP, POA&M, monitoring results) are accurate and on schedule
- Emphasis on continuous monitoring and maintaining ATO conditions over program lifecycle
- Reinforces shared responsibility model → PM ensures compliance, ISSO/ISSM execute technical details

Crosslinks

- JSIG → baseline SAP RMF implementation guide
- DoDI 8510.01 → RMF mandate for DoD IT
- CNSSI 1253 → overlays and categorization basis PMs must understand
- DAAPM → similar contractor/IC guidance for SAP programs
- eMASS → tool used to manage all RMF/JSIG artifacts

✅ Exam Lens

Expect questions on:

- The Program Manager's role in RMF execution (oversight, resources, artifacts)
- PM responsibilities across the 7 RMF steps
- How the Handbook ties JSIG policy into practical program management
- PM's relationship with AO, ISSO/ISSM, ISSE
- Accountability for continuous monitoring and ATO sustainment

Core RMF Spine

Purpose

Implements the Risk Management Framework (RMF) for cleared contractors under the National Industrial Security Program (NISP). Provides a standardized A&A (formerly C&A) process to safeguard classified information in industry, ensuring confidentiality, integrity, and availability across contracts.

Core Concepts

- RMF Transition → Moves contractor C&A process to RMF, aligning with DoD/IC practices
- Reference Publications → Built on SP 800-37, SP 800-53/53A, CNSSI 1253, and CNSSD 504 (Insider Threat)
- Insider Threat Integration → Implements minimum insider threat protections per NISPOM & EO 13587
- Reciprocity → Streamlines assessments to improve acceptance across DoD, SAP, and IC communities
- Change Management → Updated as core NIST/CNSS pubs evolve

ISSEP Takeaways

- DAAPM applies RMF to contractors in the NISP → it's the industry-facing counterpart to JSIG/8510.01
- Core security requirements = based on NIST & CNSS pubs, with insider threat requirements added
- Authorizations = conducted by DCSA for systems handling classified contracts
- Reciprocity = key driver (ensures cleared contractors don't repeat duplicative A&A)
- Must safeguard classified info while supporting mission/business continuity under contracts

Crosslinks

- NIST SP 800-37 & 53 → RMF foundation + control catalog
- SP 800-53A → control assessment procedures
- CNSSI 1253 → categorization and control overlays for NSS/contractor systems
- CNSSD 504 & EO 13587 → insider threat protections
- NISPOM → overarching contractor security manual that DAAPM implements

✅ Exam Lens

Expect questions on:

- DAAPM = RMF for cleared contractors under NISP (DCSA)
- Transition from C&A → RMF
- Integration of insider threat protections (EO 13587, CNSSD 504, NISPOM)
- Reciprocity goals across DoD, SAP, and IC
- Connection to SP 800-37, 53/53A, and CNSSI 1253

DoD & National Guidance

Purpose

The DoD CIO Library is the central repository of policies, directives, guidance, and resources maintained by the DoD Chief Information Officer. It provides authoritative references for cybersecurity, RMF implementation, cloud, IT modernization, and information assurance across the DoD enterprise.

Core Concepts

- Policy Hub → contains DoD Instructions (DoDI), Directives (DoDD), and Manuals (DoDM) for IT and cybersecurity
- RMF & Cybersecurity Guidance → includes DoDI 8510.01, 8500.01, JSIG, DAAPM, and related issuances
- Emerging Technology Guidance → cloud, zero trust, IT modernization strategies
- Centralized Access → ensures all DoD components work from authoritative, up-to-date guidance
- Alignment with Federal Policy → maps DoD-specific issuances to NIST, CNSS, and federal mandates

ISSEP Takeaways

- CIO Library is the official source for DoD cybersecurity/RMF directives
- Critical for ensuring policy compliance and accessing current guidance
- Know it as the DoD repository — exam may reference it as the central location for policy documents
- Used by ISSOs/ISSEs/PMs to verify correct and current DoD guidance is applied to programs

Crosslinks

- DoDI 8510.01 → DoD RMF policy
- DoDI 8500.01 → overarching DoD cybersecurity policy
- JSIG & DAAPM → found within the CIO Library as SAP/IC overlays
- NIST Pubs → referenced for alignment with federal standards

✅ Exam Lens

Expect questions on:

- CIO Library = DoD central policy repository
- Its role in providing authoritative guidance for RMF/cybersecurity
- How it supports policy alignment with NIST/CNSS
- Importance of verifying latest versions of DoD directives come from the CIO Library

Purpose

Establishes the DoD's overarching cybersecurity policy and governance framework. Defines requirements for protecting DoD information, IT, and weapons systems, and sets the foundation for implementing the RMF (via DoDI 8510.01).

Core Concepts

- Applies to all DoD IT → NSS, PIT, cloud, services, and contractor systems supporting DoD missions
- Defines cybersecurity responsibilities for DoD Components, CIO, Risk Executive, AOs, ISSMs, and ISSOs
- Requires use of RMF (DoDI 8510.01) and NIST/CNSS standards for risk-based security
- Emphasizes defense-in-depth, continuous monitoring, and resilience
- Addresses supply chain, insider threat, and mission assurance as core security drivers

ISSEP Takeaways

- 8500.01 = top-level DoD cybersecurity policy; 8510.01 = RMF execution
- Cybersecurity is mandatory across all DoD IT, not just NSS
- Establishes roles and responsibilities → CIO, Risk Executive, AOs, ISSMs, ISSOs
- ISSO/ISSE actions flow down from 8500.01 requirements → implemented via RMF/controls
- Policy covers technical, operational, and organizational aspects of DoD cybersecurity

Crosslinks

- DoDI 8510.01 → enforces RMF process that 8500.01 mandates
- CNSSI 1253 → overlays used for NSS categorization/control selection
- JSIG / DAAPM → tailored for SAP and IC environments
- DoD CIO Library → authoritative source of 8500.01 and related issuances
- NIST SP 800-37 / 53 → referenced for RMF and controls

✅ Exam Lens

Expect questions on:

- DoDI 8500.01 = overarching DoD cybersecurity policy
- Distinction between 8500.01 (policy) and 8510.01 (RMF execution)
- Applicability to all DoD IT systems (NSS + non-NSS + PIT + cloud)
- Defined cybersecurity roles and responsibilities
- How it ties to RMF, CNSSI 1253, and SAP/IC overlays

Purpose

Developed by the Center for Development of Security Excellence (CDSE), these toolkits provide practical resources, checklists, templates, and training for Information System Security Managers (ISSMs) and Information System Security Officers (ISSOs). They translate high-level DoD policy into actionable guidance for day-to-day security operations.

Core Concepts

- Role-Based Guidance → defines ISSM vs ISSO responsibilities under RMF and DoD policy
- Practical Resources → templates, checklists, job aids, and compliance guides
- Training & Awareness → online modules, case studies, insider threat integration
- Lifecycle Focus → supports RMF activities from categorization through continuous monitoring
- Compliance Alignment → maps responsibilities to DoDI 8500.01, 8510.01, JSIG, and DAAPM

ISSEP Takeaways

- Toolkits = practical job aids for ISSMs and ISSOs executing RMF tasks
- Ensure day-to-day actions align with DoD cybersecurity directives and RMF requirements
- Reinforce ISSM (management/oversight) vs ISSO (operational execution) distinctions
- Provide supporting material for continuous monitoring and audit readiness
- Not policy themselves, but authoritative references endorsed by DoD

Crosslinks

- DoDI 8500.01 & 8510.01 → define roles and requirements the toolkits support
- JSIG / DAAPM → specialized environments where ISSMs/ISSOs operate
- NISPOM & DAAPM → relevant to contractor ISSMs/ISSOs under DCSA oversight
- NIST SP 800-37 → RMF steps these toolkits help carry out

✅ Exam Lens

Expect questions on:

- Purpose of CDSE Toolkits = role-specific resources for ISSM/ISSO
- Difference between ISSM (managerial) and ISSO (operational) responsibilities
- How toolkits tie to DoDI 8500.01, 8510.01, JSIG, DAAPM
- Use for training, checklists, templates, and compliance aids
- Recognition that toolkits = practical aids, not policy documents

DoD & National Guidance

Purpose

The NSA Information Assurance Technical Framework (IATF) provides technical guidance and best practices for implementing information assurance (IA) in DoD and national security systems. It establishes a common baseline for protecting systems against cyber threats and supports defense-in-depth across architectures.

Core Concepts

- Defense-in-Depth Model → layered protection across people, technology, and operations
- Technical Framework → architecture-level controls, IA services, and security mechanisms
- IA Functions → availability, integrity, authentication, confidentiality, non-repudiation
- Cross-Domain & Network Security Guidance → firewalls, VPNs, crypto, IDS/IPS, boundary protections
- Mission Assurance Alignment → emphasizes resilient architectures that can operate under attack

ISSEP Takeaways

- IATF = technical playbook for implementing IA within DoD systems
- Understand defense-in-depth as the cornerstone concept
- Provides system/architecture-level guidance rather than policy mandates
- Ties directly to risk management → IA controls ensure mission assurance in contested environments
- Supplements, but does not replace, NIST and DoD policy frameworks

Crosslinks

- DoDI 8500.01 & 8510.01 → IATF provides the technical foundation to achieve compliance
- SP 800-160 → ties into engineering secure/resilient systems
- SP 800-53 → IATF concepts map into control families (esp. AC, SC, SI)
- JSIG / DAAPM → SAP/IC programs rely on IATF guidance for implementing layered defenses

✅ Exam Lens

Expect questions on:

- NSA IATF = technical framework for IA (not a policy doc)
- Core principle = defense-in-depth
- IA functions (availability, integrity, confidentiality, authentication, non-repudiation)
- How it supports mission assurance & resiliency
- Relationship to DoD RMF policies (8500.01/8510.01) and NIST pubs

Risk & Contingency Standards

Purpose

Provides a structured, organization-wide approach to managing information security risk. Focuses on integrating risk management into strategic, organizational, and system-level decision-making to support mission and business success.

Core Concepts

- Three Tiers of Risk Management
  - Tier 1: Organization / Governance (risk framing, policies, strategy)
  - Tier 2: Mission / Business Process (risk-aware processes, priorities)
  - Tier 3: Information Systems (RMF-level risk application)
- Risk Management Cycle → Frame, Assess, Respond, Monitor
- Risk Framing → Establish context, assumptions, and risk tolerance
- Enterprise-Wide Integration → ensures consistency of risk decisions across levels

ISSEP Takeaways

- 800-39 = strategic-level risk guide → sets the big picture for RMF
- Must understand the three tiers and how they connect (Org → Mission → Systems)
- RMF steps (37) operate primarily at Tier 3, but are informed by Tier 1 & 2 context
- Risk framing drives categorization, baseline tailoring, and risk response decisions
- Emphasis on continuous monitoring & feedback across tiers

Crosslinks

- SP 800-30 → provides detailed risk assessment methodology (step inside "Assess")
- SP 800-37 → RMF applies the risk cycle at system level (Tier 3)
- SP 800-53 → control catalog used in risk response
- SP 800-137 → supports continuous monitoring (Monitor step)
- CNSSI 1253 → overlays ensure DoD/IC risk alignment

✅ Exam Lens

Expect questions on:

- The three tiers of risk management (organization, mission, system)
- The risk management cycle (Frame, Assess, Respond, Monitor)
- How 800-39 sets strategy and context for RMF (800-37 at system level)
- Risk framing → why it matters, what it defines (assumptions, constraints, tolerance)
- Integration of risk across all levels of the enterprise

Risk & Contingency Standards

Purpose

Provides the methodology for conducting risk assessments of federal information systems. Supports organizational risk management by identifying threats, vulnerabilities, impacts, and likelihoods to determine overall risk.

Core Concepts

• Risk Assessment Process →
– Prepare for assessment
– Conduct assessment (identify threat sources/events, vulnerabilities, likelihood, impact, risk determination)
– Communicate results
– Maintain assessment (updates, ongoing monitoring)
• Threats → natural, human, environmental, supply chain, insider, external adversary
• Vulnerabilities → system flaws, misconfigs, weak processes, human factors
• Likelihood & Impact → combine to determine risk levels
• Output → informs RMF Categorize, Select, and Authorize steps

ISSEP Takeaways

• 800-30 = "how to do risk assessments" in RMF context
• Links directly into RMF Step 1: Prepare and Step 2: Categorize
• Assessment is iterative → updated as threats/tech change
• Risk = function of threat × vulnerability × impact × likelihood
• Supports enterprise risk cycle from SP 800-39

Crosslinks

• SP 800-39 → overall risk management strategy; 800-30 = assessment piece
• SP 800-37 → RMF process that consumes risk assessment results
• SP 800-53 → control selection guided by assessed risks
• SP 800-34 → contingency planning based on assessment findings
• SP 800-137 → continuous monitoring ensures assessments stay current

✅ Exam Lens

Expect questions on:
• Risk assessment steps & process (Prepare, Conduct, Communicate, Maintain)
• Key inputs (threats, vulnerabilities, likelihood, impact) and outputs (risk results)
• Relationship between 800-30 and RMF Categorize/Select steps
• How results guide control selection and risk response
• The role of iteration and continuous monitoring

Risk & Contingency Standards

Purpose

Provides guidance for developing and implementing contingency planning for federal information systems. Ensures agencies can recover and continue operations after disruptions caused by cyber incidents, natural disasters, or system failures.

Core Concepts

- Contingency Planning Cycle → Initiation → Development → Implementation → Testing → Maintenance
- Types of Plans →
  - Business Continuity Plan (BCP)
  - Continuity of Operations Plan (COOP)
  - Crisis Communications Plan
  - Disaster Recovery Plan (DRP)
  - Incident Response Plan (IRP)
  - Occupant Emergency Plan (OEP)
- System Recovery Priorities → RTO (Recovery Time Objective), RPO (Recovery Point Objective)
- Testing & Exercises → tabletop, functional, full-scale to validate effectiveness
- Integration → Plans must align with org-wide risk mgmt strategy (800-39) and RMF Monitor step

ISSEP Takeaways

- 800-34 = how to build & maintain contingency/continuity plans
- ISSOs/ISSEs must ensure critical systems have recovery objectives and tested plans
- Contingency planning is cyclical and continuous, not one-time
- Ties closely to mission/business assurance (system downtime = mission risk)
- Testing/exercising plans is just as important as developing them

Crosslinks

- SP 800-39 → organizational risk strategy drives continuity requirements
- SP 800-30 → risk assessments identify scenarios for planning
- SP 800-37 (RMF) → contingency planning aligns with RMF Step 7 (Monitor)
- SP 800-53 → CP family (Contingency Planning controls)
- SP 800-137 → continuous monitoring of recovery controls

✅ Exam Lens

Expect questions on:

- Purpose of contingency planning (recover/continue operations)
- The planning cycle (initiate → develop → implement → test → maintain)
- Difference between plan types (BCP vs COOP vs DRP vs IRP, etc.)
- RTO and RPO definitions and significance
- Importance of testing and exercises

Risk & Contingency Standards

Purpose

Defines the process for implementing Information Security Continuous Monitoring (ISCM) across federal systems. Ensures that security posture, risks, and control effectiveness are continuously assessed and reported, enabling ongoing authorization and timely risk response.

Core Concepts

- ISCM Program → establish strategy, define metrics, select tools, implement processes
- Lifecycle Steps → Define → Establish → Implement → Analyze/Report → Respond → Review/Update
- 137 (Core Guide) → describes ISCM concepts, program structure, and integration with RMF Step 7 (Monitor)
- 137A (Assessment Procedures) → provides practical methods for testing and validating controls continuously
- Metrics & Automation → relies on automated feeds (e.g., SIEM, SCAP tools) to support near real-time awareness
- Ongoing Authorization → continuous monitoring replaces static "point-in-time" ATOs

ISSEP Takeaways

- 137 = policy/methodology; 137A = detailed procedures
- Continuous monitoring is essential for ongoing risk management and ATO sustainment
- Requires integration of people, processes, and technology (not just tools)
- ISSO/ISSM responsibility → ensure monitoring plans are developed and executed
- Supports continuous risk-informed decisions by Authorizing Officials

Crosslinks

- SP 800-37 → RMF Step 7 (Monitor)
- SP 800-53 → monitoring and assessment controls (CA, SI, AU families)
- SP 800-30 → ongoing risk assessments informed by monitoring
- SP 800-115 → technical testing/validation complements monitoring
- SCAP (126/117/7511) → automation framework for ISCM data feeds

✅ Exam Lens

Expect questions on:

- Difference between 137 (concepts/program) and 137A (assessment procedures)
- Purpose of ISCM = ongoing awareness, ongoing authorization
- Lifecycle steps of ISCM programs
- Relationship to RMF Step 7 (Monitor)
- Role of automation and metrics in continuous monitoring

Risk & Contingency Standards

Purpose

Provides guidance for planning and conducting information security assessments, including penetration testing, vulnerability scanning, and security reviews. Establishes a structured process for evaluating security controls and identifying weaknesses in federal systems.

Core Concepts

- Assessment Techniques →
  - Testing (e.g., penetration testing, red/blue team, fuzzing)
  - Examination (e.g., documentation reviews, checklists, interviews)
  - Interviewing (e.g., discussions with personnel, process validation)
- Phases of Testing → Planning → Discovery → Attack → Reporting
- Scope & Rules of Engagement → authorization, boundaries, legal considerations
- Integration → results feed into risk assessments, RMF control assessments, and remediation plans

ISSEP Takeaways

- 800-115 = how to conduct technical assessments and pen tests
- Recognize difference between testing, examination, and interviewing techniques
- Pen testing is structured and controlled → must align with organizational rules and authorizations
- Outputs inform RMF Assess and Monitor steps (control effectiveness, risk posture)
- Essential for validating technical controls against adversary tactics

Crosslinks

- SP 800-37 → supports Assess and Monitor steps in RMF
- SP 800-53A → formal control assessment procedures
- SP 800-30 → risk assessment framework that testing feeds into
- SP 800-137 → continuous monitoring programs use technical assessment results
- DISA STIGs & SCAP → complementary automated testing/enforcement frameworks

✅ Exam Lens

Expect questions on:

- Assessment methods (Testing vs Examination vs Interviewing)
- Penetration testing phases (Plan, Discover, Attack, Report)
- Purpose of pen testing = validate control effectiveness, identify vulnerabilities
- Relationship of 800-115 results to RMF Assess/Monitor steps
- Importance of scope, authorization, and legal boundaries

🛠 Engineering & Architecture Standards

Purpose

Provides a systems security engineering framework for developing trustworthy secure systems. Aligns with ISO/IEC/IEEE 15288 life cycle processes and embeds security as a core element of systems engineering across the full life cycle.

Core Concepts

- Integration with Systems Engineering → adapts 15288 processes to include security considerations
- Trustworthiness Attributes → safety, security, reliability, resilience, survivability
- Multidisciplinary Approach → security woven into requirements, architecture, design, implementation, and sustainment
- Life Cycle Coverage → from concept → development → operations → disposal
- Systems Security Engineering Processes → applied to requirements analysis, risk trade-offs, and assurance development

ISSEP Takeaways

- 800-160 Vol. 1 = how to engineer secure systems from the ground up
- Security = part of systems engineering, not an afterthought
- Focus on trustworthiness attributes and their role in mission assurance
- Supports ISSO/ISSE roles → ensuring design decisions reflect risk/security trade-offs
- Essential link between RMF (risk) and systems engineering (design/build)

Crosslinks

- ISO/IEC/IEEE 15288 → foundation life cycle processes adapted for security
- SP 800-37 (RMF) → applies risk mgmt across system life cycle
- SP 800-53 → control catalog implemented via engineering processes
- SP 800-160 Vol. 2 → extends SSE into cyber resiliency
- INCOSE SE Handbook → complementary engineering guidance

✅ Exam Lens

Expect questions on:

- 800-160 Vol. 1 = Systems Security Engineering framework
- Relationship to 15288 and systems engineering processes
- Definition of trustworthiness attributes (safety, security, reliability, resilience, survivability)
- How SSE integrates into the system life cycle
- Difference between Vol. 1 (engineering trustworthiness) vs Vol. 2 (cyber resiliency)

🛠 Engineering & Architecture Standards

Purpose

Extends systems security engineering to cyber resiliency engineering — designing systems that can anticipate, withstand, recover, and adapt to advanced cyber threats (including APTs). Provides a framework for embedding resiliency into system life cycle processes.

Core Concepts

- Cyber Resiliency Engineering Framework → Goals, Objectives, Techniques, Implementation Approaches, Design Principles
- Resiliency Capabilities → anticipate, withstand, recover, adapt
- Resiliency Analysis Approach → tailorable process to evaluate system resiliency properties
- Adversary-Oriented View → considers how resiliency mitigates adversary TTPs
- Integration → intended for use with SP 800-160 Vol. 1 (SSE), SP 800-37 (RMF), SP 800-53 (controls)

ISSEP Takeaways

- Vol. 2 = specialty discipline: cyber resiliency engineering
- Constructs are modular and tailorable — applied based on system/mission needs
- Resiliency outcomes = mission assurance, continuity, and survivability under attack
- Maps directly to SP 800-53 controls that support resiliency (esp. SC, SI, CP, SR families)
- Supports risk-based engineering decisions against APTs and evolving threat environments

Crosslinks

- SP 800-160 Vol. 1 → foundation SSE processes
- SP 800-37 (RMF) → resiliency aligned with Prepare, Monitor, and ongoing risk management
- SP 800-53 → identifies control families linked to resiliency goals
- ISO/IEC/IEEE 15288 → life cycle processes adapted for resiliency focus

✅ Exam Lens

Expect questions on:

- The four resiliency capabilities (anticipate, withstand, recover, adapt)
- Difference between Vol. 1 (trustworthy systems) and Vol. 2 (resilient systems)
- Cyber resiliency framework constructs (goals, objectives, techniques, principles)
- Relationship to SP 800-53 resiliency-related controls
- Mission/business assurance outcomes in the face of APT-level threats

Engineering & Architecture Standards

Purpose

Provides a framework for managing cybersecurity risks in supply chains. Integrates C-SCRM into organizational risk management, acquisition, and system engineering to reduce threats from untrusted suppliers, counterfeit components, and compromised services.

Core Concepts

• Integration Across Enterprise Levels →
– Tier 1: Enterprise governance
– Tier 2: Mission / Business process
– Tier 3: System / Operational implementation
• Roles & Responsibilities → ERM owners, procurement, engineers, security/privacy officials, PMOs
• Critical Success Factors → acquisition strategy, lifecycle planning, supplier oversight, measurement
• C-SCRM Security Controls → based on SP 800-53 families with supply chain–specific requirements (SR family)
• Risk Exposure Framework → scenarios include foreign influence, counterfeits, espionage, malicious code insertion, reused vulnerable components
• Templates & Tools → strategy, policy, and plan templates for standardized implementation
• Alignment with Federal Policy → supports FASCSA and EO 14028 (software supply chain security)

ISSEP Takeaways

• 800-161 = supply chain cybersecurity playbook
• C-SCRM must be embedded at all tiers of the enterprise (governance → mission → systems)
• Controls extend SP 800-53 with supply chain overlays (esp. SR family)
• Risk scenarios highlight the mission/business impact of supply chain compromise
• Provides standardized templates and measurable practices for C-SCRM programs

Crosslinks

• SP 800-39 → enterprise risk mgmt context; C-SCRM integrated into org strategy
• SP 800-37 (RMF) → C-SCRM activities mapped to RMF steps (Frame, Assess, Respond, Monitor)
• SP 800-53 → baseline control families; SR controls address supply chain threats
• CNSSI 1253 → overlays for NSS environments
• EO 14028 & FASCSA → federal directives on supply chain risk mgmt

✅ Exam Lens

Expect questions on:
• Definition and purpose of C-SCRM
• The three levels of integration (enterprise, mission, system)
• How C-SCRM ties into RMF and risk mgmt frameworks
• Supply chain control family (SR) in SP 800-53
• Risk scenarios (counterfeits, foreign influence, malicious code, reused vulnerable components)

🛠 Engineering & Architecture Standards

Purpose

Defines the international standard for system life cycle processes. Provides a common framework for managing the life cycle of systems — from concept through disposal — ensuring consistency across engineering, management, and technical disciplines.

Core Concepts

- Life Cycle Coverage → concept → development → production → operation → maintenance → disposal
- Process Groups →
  - Agreement Processes (e.g., acquisition, supply)
  - Organizational Project-Enabling Processes (e.g., portfolio, life cycle management)
  - Technical Management Processes (e.g., planning, risk mgmt, decision analysis)
  - Technical Processes (e.g., requirements, architecture, design, integration, verification, validation)
- Security as a Quality Attribute → incorporated into engineering processes when paired with NIST SP 800-160
- Consistency & Interoperability → provides a global standard baseline across industries and nations

ISSEP Takeaways

- 15288 = foundational life cycle standard → NIST SP 800-160 builds directly on it
- Recognize the process groups and how they map to systems engineering activities
- Emphasizes integration of security as part of system quality (not bolted on later)
- Supports ISSOs/ISSEs in aligning security with engineering trade-offs and project management
- Provides international recognition → DoD and NIST leverage it to align with allies/partners

Crosslinks

- SP 800-160 Vol. 1 → adapts 15288 processes specifically for Systems Security Engineering (SSE)
- SP 800-160 Vol. 2 → cyber resiliency engineering also grounded in 15288
- INCOSE SE Handbook → practical companion and interpretation of 15288
- ISO/IEC/IEEE 42010 → architecture framework that complements system life cycle processes

✅ Exam Lens

Expect questions on:

- Purpose of 15288 = international systems life cycle framework
- The four process groups (agreement, enabling, management, technical)
- How NIST SP 800-160 uses 15288 as its foundation
- Security as a quality attribute integrated across the life cycle
- Relationship to INCOSE Handbook and ISO/IEC/IEEE 42010

Engineering & Architecture Standards

Purpose

Defines the international standard for describing system and software architectures. Provides guidance for creating architecture frameworks and viewpoints to ensure complex systems are well-structured, interoperable, and traceable to stakeholder needs.

Core Concepts

- Architecture Description (AD) → a formal set of work products that documents an architecture
- Stakeholder Viewpoints → each viewpoint addresses specific stakeholder concerns (e.g., security, performance, interoperability)
- Architecture Frameworks → standardized collections of viewpoints and rules (e.g., DoDAF, TOGAF, Zachman)
- Consistency & Traceability → ensures architectures align with system requirements and are comparable across projects
- Architecture vs Design → 42010 focuses on high-level structure, not detailed implementation

ISSEP Takeaways

- 42010 = architecture description standard, ensuring stakeholders' needs are addressed formally
- Helps ISSOs/ISSEs verify security requirements are reflected in architecture products
- Provides structure for defense/DoD architecture frameworks (DoDAF) used in acquisition and system engineering
- Reinforces traceability from stakeholder concerns → architecture decisions → implementation
- Exam expects familiarity with how architecture frameworks organize viewpoints

Crosslinks

- ISO/IEC/IEEE 15288 → life cycle standard that 42010 supports at the architecture level
- SP 800-160 Vol. 1 → integrates security into systems engineering, including architecture design
- INCOSE SE Handbook → practical companion for system/architecture engineering
- DoDAF (Department of Defense Architecture Framework) → direct U.S. application of 42010 principles

✅ Exam Lens

Expect questions on:

- 42010 = architecture framework & description standard
- Concept of viewpoints addressing different stakeholder concerns
- Relationship to DoDAF, TOGAF, Zachman as examples of frameworks
- Role of architecture descriptions in ensuring traceability and consistency
- How architecture frameworks tie into system life cycle processes (15288) and SSE (800-160)

Engineering & Architecture Standards

Purpose

Serves as the practical guide to systems engineering (SE) published by the International Council on Systems Engineering (INCOSE). Interprets and expands on ISO/IEC/IEEE 15288, providing methods, best practices, and terminology to implement SE across the system life cycle.

Core Concepts

- Life Cycle Coverage → concept, development, production, utilization, support, retirement
- SE Processes → requirements definition, architecture/design, integration, verification, validation, transition
- Stakeholder-Driven Approach → emphasizes translating mission needs into system requirements
- Systems Thinking → holistic view of interactions, trade-offs, and complexity
- Practical Guidance → checklists, tailoring advice, and examples to help apply 15288 consistently

ISSEP Takeaways

- INCOSE Handbook = how to apply 15288 in practice
- Emphasis on stakeholder requirements and traceability → critical for aligning security with mission/business goals
- Reinforces V-model development (requirements → design → build → test → deployment)
- Security is not a separate process but integrated into all SE activities
- Useful for understanding how NIST SP 800-160 adapts systems engineering to security

Crosslinks

- ISO/IEC/IEEE 15288 → foundational SE processes, expanded in INCOSE guidance
- SP 800-160 Vol. 1 → Systems Security Engineering adapts INCOSE principles for trustworthy systems
- SP 800-160 Vol. 2 → resiliency considerations added to SE
- ISO/IEC/IEEE 42010 → architectural viewpoints supported by SE practices

✅ Exam Lens

Expect questions on:

- INCOSE Handbook = practical interpretation of 15288
- Relationship to NIST SP 800-160 (security = integrated into SE processes)
- Importance of stakeholder needs → system requirements → system design
- The V-model as a representation of SE activities
- SE as the foundation discipline that security engineering builds on

🛠 Engineering & Architecture Standards

Purpose

Defines the international standard for evaluating IT product security. Provides a framework (Common Criteria, CC) for specifying and assessing security requirements, and the Common Evaluation Methodology (CEM) for conducting standardized, repeatable evaluations.

Core Concepts

- Common Criteria (CC) → international standard (ISO/IEC 15408) for evaluating security of IT products and systems
- Security Targets (ST) → product-specific security requirements and claims
- Protection Profiles (PPs) → reusable, standardized sets of security requirements for product categories
- Evaluation Assurance Levels (EAL 1–7) → scale for depth/rigor of evaluation (from basic functional testing to formal verification)
- Common Evaluation Methodology (CEM) → defines how evaluations are performed to ensure consistency across labs/nations
- Mutual Recognition → Common Criteria Recognition Arrangement (CCRA) allows global acceptance of evaluations up to EAL 2 or 4 (depending on country)

ISSEP Takeaways

- CC = global standard for product assurance; CEM = evaluation process
- PPs = define what a class of products should achieve (e.g., firewalls)
- STs = vendor's specific claims about their product → tested against CC/CEM
- EALs = shorthand for assurance level, but functional suitability matters more than the number
- Relevance to ISSEP = ensures products meet baseline assurance requirements before being integrated into secure systems

Crosslinks

- SP 800-160 Vol. 1 → CC supports trustworthiness by validating product security
- SP 800-37/53 → CC products may fulfill control requirements (SC, IA, SI families)
- INCOSE & 15288 → product assurance tied into system engineering processes
- NSA IATF → uses CC evaluations to validate IA components (crypto, firewalls, OSs)

✅ Exam Lens

Expect questions on:

- CC = product evaluation framework, CEM = evaluation methodology
- Difference between Protection Profile (PP) and Security Target (ST)
- Purpose of EALs (1–7) and what higher levels mean
- Role of CC/CEM in ensuring trustworthy components
- How evaluated products tie back into controls and secure system design

Purpose

Provide mandatory configuration standards for DoD systems, applications, and devices. STIGs (Security Technical Implementation Guides) ensure systems are securely configured and hardened to reduce vulnerabilities and support RMF authorization.

Core Concepts

- STIGs → prescriptive guidance for secure configuration of OSs, databases, apps, networks, cloud, and hardware
- Checklists (XCCDF format) → machine-readable files used for automated compliance scanning
- Categories of Findings → CAT I (severe), CAT II (moderate), CAT III (low)
- Lifecycle Use → applied during implementation, validated during Assess step, maintained during Monitor step
- Enforcement → required for DoD ATO; non-compliance tracked in POA&Ms

ISSEP Takeaways

- STIGs = DoD baseline hardening standard
- Compliance is mandatory for ATO under DoDI 8510.01 RMF
- ISSO/ISSM role → ensure STIG findings are tracked, mitigated, or accepted with risk
- Checklists integrate with SCAP tools for automation (ACAS, SCC, STIG Viewer)
- STIGs map to SP 800-53 controls (esp. CM, SI, SC families)

Crosslinks

- SP 800-37 (RMF) → STIG compliance central to Implement, Assess, Monitor steps
- SP 800-53 → STIG requirements map to control families
- SCAP (SP 800-126/117/IR 7511) → automation framework for checklist validation
- NISPOM/DAAPM → STIGs often required in cleared contractor environments
- 137 (Continuous Monitoring) → STIG checks feed ISCM dashboards

✅ Exam Lens

Expect questions on:

- What STIGs are and their purpose in DoD security
- Difference between STIGs vs Checklists (human-readable vs machine-readable XCCDF)
- STIG categories (CAT I/II/III severity)
- How STIG compliance ties into RMF ATO and POA&M tracking
- Relationship between STIGs, SCAP automation, and 800-53 controls

DoD Cybersecurity Policies

Purpose

Defines and maintains the Security Content Automation Protocol (SCAP) repositories used to automate compliance checking. NIST IR 7511 specifies the SCAP content requirements and mappings to NIST controls and DISA STIGs.

Core Concepts

- SCAP = XML-based framework for automating security checks (config, patch, vuln mgmt)
- Repositories → centralized sources of SCAP content (e.g., NVD, DISA STIG repositories)
- NIST IR 7511 → defines SCAP mappings to NIST SP 800-53 control families
- SCAP Components → OVAL (vuln definitions), XCCDF (checklists), CPE (product naming), CVE/CVSS (vuln identifiers/metrics)
- Automation Use → SCAP content enables automated scanners (ACAS, SCC, Nessus, etc.) to check STIG/NIST compliance

ISSEP Takeaways

- SCAP repositories provide the content backbone for automated compliance tools
- NIST IR 7511 links SCAP content to SP 800-53 controls
- Ensures consistency and repeatability of assessments across agencies
- ISSOs/ISSEs must know SCAP = how STIGs and checklists are machine-enforced
- Supports continuous monitoring and RMF Assess/Monitor steps

Crosslinks

- SP 800-126 → SCAP specification standard
- SP 800-117 → SCAP tool requirements
- SP 800-37 (RMF) → automation supports Monitor step
- SP 800-137 → ISCM programs rely on SCAP-enabled tools
- DISA STIGs → primary SCAP use case for configuration compliance

✅ Exam Lens

Expect questions on:

- Purpose of SCAP repositories (centralized, authoritative content)
- NIST IR 7511 = maps SCAP content to 800-53 controls
- Key SCAP components (OVAL, XCCDF, CPE, CVE/CVSS)
- How SCAP enables automation of STIG/NIST compliance
- Role in continuous monitoring and RMF automation

DoD Cybersecurity Policies

Purpose

Defines the technical specification for SCAP — a suite of XML-based standards for automating security configuration, vulnerability management, and compliance assessment. Provides the format and interoperability rules for SCAP content.

Core Concepts

- SCAP Components →
  - XCCDF: checklist definitions
  - OVAL: vulnerability/patch/config checks
  - CPE: standardized product naming
  - CVE: vulnerability identifiers
  - CVSS: vulnerability severity scoring
  - OCIL: questionnaire format (optional)
- SCAP Validation → ensures tools/content conform to the standard
- Interoperability → SCAP ensures different tools use the same definitions and produce consistent results
- Automation → enables machine-enforceable compliance with DISA STIGs, NIST baselines, and 800-53 controls

ISSEP Takeaways

- 800-126 = the "rulebook" for SCAP content
- ISSOs/ISSEs don't author SCAP but must understand its role in automated compliance
- Supports RMF Assess & Monitor by standardizing checks across tools
- SCAP is the enabler for repeatable, machine-readable compliance validation
- Validated SCAP tools are required in federal/DoD environments (e.g., ACAS, SCC)

Crosslinks

- NIST IR 7511 → maps SCAP content to 800-53 controls
- SP 800-117 → defines SCAP tool requirements
- DISA STIGs & Checklists → primary content expressed in SCAP formats
- SP 800-137 → ISCM relies on SCAP automation for continuous monitoring
- SP 800-37 (RMF) → automation strengthens Monitor step

✅ Exam Lens

Expect questions on:

- 800-126 = specification for SCAP content
- Key SCAP components (XCCDF, OVAL, CPE, CVE, CVSS, OCIL)
- Why SCAP matters → automation, consistency, interoperability
- Relationship to STIGs, 800-53 controls, and continuous monitoring
- Role of SCAP validation (ensuring tool/content conformity)

DoD Cybersecurity Policies

Purpose

Provides guidance on adopting and using SCAP-enabled tools for security automation. Focuses on how organizations can leverage SCAP content and validated tools to support compliance, vulnerability management, and continuous monitoring.

Core Concepts

- SCAP Adoption → guidance on selecting, deploying, and integrating SCAP-compliant tools
- Validated Tools → must meet NIST validation for proper SCAP functionality (interoperability & accuracy)
- Use Cases → vulnerability scanning, configuration checking (STIGs, baselines), inventory reporting, patch verification
- Automation Benefits → consistency, scalability, reduced manual effort, supports continuous monitoring
- Integration → SCAP tools feed into enterprise compliance dashboards (e.g., ACAS, Splunk, SCCM extensions)

ISSEP Takeaways

- 800-117 = practical "how-to" for using SCAP tools in operations
- ISSOs/ISSMs should know SCAP tools = mandatory for federal/DoD environments
- SCAP adoption supports RMF Assess & Monitor steps and continuous ATO processes
- Validated SCAP tools = authoritative compliance results recognized across DoD/IC
- Use cases directly align with daily ISSO/ISSE tasks (patches, configs, reporting)

Crosslinks

- SP 800-126 → defines SCAP specification that tools must support
- NIST IR 7511 → maps SCAP content to 800-53 controls
- SP 800-137 → continuous monitoring programs depend on SCAP data feeds
- DISA STIGs → SCAP tools enforce compliance with machine-readable STIG checklists
- SP 800-115 → penetration testing/assessments complement automated SCAP scanning

✅ Exam Lens

Expect questions on:

- 800-117 = adoption and use of SCAP-enabled tools
- Why SCAP tool validation matters (accuracy, interoperability, trust)
- Core use cases (vuln scanning, config checking, patch validation, reporting)
- Relationship to RMF Assess/Monitor and Continuous ATO
- How SCAP tools enforce STIGs & 800-53 control compliance

SCAP & SOAR

Purpose

Provides the federal standard for automating security configuration, vulnerability, and compliance management. SCAP defines a framework of specifications, tools, and repositories to enable machine-readable, repeatable, and authoritative assessments of system security posture.

Core Concepts

• SCAP Components →
– XCCDF (checklist rules)
– OVAL (vulnerability/config checks)
– CPE (standardized product naming)
– CVE (vulnerability IDs)
– CVSS (vulnerability severity scoring)
– OCIL (questionnaires, optional)
• SCAP Repositories (NIST IR 7511) → authoritative source of content (NVD, DISA STIGs)
• SCAP Specification (SP 800-126) → defines the technical standards for SCAP content
• SCAP Tools (SP 800-117) → validated tools required for compliance automation (e.g., ACAS, SCC, Nessus)
• Automation Benefits → consistency, reduced human error, compliance at scale, supports Continuous Monitoring & Continuous ATO

ISSEP Takeaways

• SCAP = the backbone of compliance automation in DoD and federal systems
• ISSOs/ISSMs must ensure use of validated SCAP tools + content from trusted repos
• SCAP ties directly into RMF Assess & Monitor by automating control checks
• Supports continuous monitoring dashboards and risk-informed ATO decisions
• DoD/NIST use SCAP to align STIGs, baselines, and vulnerabilities into a unified framework

Crosslinks

• SP 800-37 (RMF) → SCAP supports Monitor step via automation
• SP 800-137 → ISCM relies on SCAP data feeds
• SP 800-53 → SCAP checks align to control families (esp. CM, SI, SC)
• DISA STIGs → distributed in SCAP formats for automated enforcement
• FISMA → SCAP supports mandated compliance reporting

✅ Exam Lens

Expect questions on:
• SCAP = framework of specs + tools + repos for automation
• Key SCAP components (XCCDF, OVAL, CPE, CVE, CVSS, OCIL)
• Difference between spec (126), tools (117), and repos (7511)
• How SCAP enables continuous monitoring and ATO sustainment
• Why only validated SCAP tools and authoritative repositories can be trusted

SCAP & SOAR

Purpose

SOAR platforms provide automation and orchestration of security workflows. They allow organizations to collect security data, standardize response processes, and automate routine tasks — reducing workload on analysts and improving incident response speed.

Core Concepts

- Three Pillars of SOAR →
  - Orchestration → integrate multiple tools (SIEM, ticketing, threat intel, firewalls, EDR)
  - Automation → scripted or playbook-driven execution of repetitive tasks (alert triage, enrichment, blocking IPs)
  - Response → coordinated, standardized incident handling with audit trails
- Playbooks → predefined workflows for common incidents (e.g., phishing, malware, insider threat)
- Integration with SIEM → SOAR ingests SIEM alerts, enriches with threat intel, and executes automated responses
- Efficiency & Scale → frees up analysts for high-level tasks, reduces dwell time, ensures consistent response

ISSEP Takeaways

- SOAR = tool class, not a single product or NIST pub
- ISSOs/ISSEs should understand how SOAR fits into continuous monitoring and incident response
- Benefits: speed, consistency, reduced human error, compliance support
- SOAR + SCAP = automation at two levels (SCAP = compliance checks, SOAR = incident workflows)
- Adoption of SOAR is consistent with RMF Monitor and Respond functions

Crosslinks

- SP 800-137 (ISCM) → SOAR extends continuous monitoring with automated responses
- SP 800-115 (Pen Testing) → SOAR can automate validation and follow-up actions
- SP 800-53 (IR family controls) → SOAR supports Incident Response requirements
- SCAP Framework → SOAR consumes automated compliance/vulnerability data as inputs
- Splunk, Qmulos, ACAS → common enterprise tools integrated with SOAR

✅ Exam Lens

Expect questions on:

- SOAR = Security Orchestration, Automation & Response
- Three functions: orchestration, automation, response
- Difference between SOAR and SCAP (compliance vs response automation)
- Role of SOAR in reducing analyst workload and improving incident handling
- Relationship to RMF Monitor step and IR controls

Laws & Mandates

Purpose

Establishes the legal requirement for federal agencies to implement information security programs to protect information and systems. Forms the foundation for NIST's RMF publications and mandates annual reporting to OMB and Congress.

Core Concepts

- Agency Accountability → heads of agencies must implement organization-wide information security programs
- Risk-Based Approach → requires security proportional to risk and mission criticality
- NIST Role → directs NIST to create standards/guidelines (FIPS, NIST SP 800-series) for federal IT security
- OMB Oversight → agencies report compliance annually to OMB → Congress
- Modernization (2014 update) → clarified roles of DHS, emphasized continuous monitoring over static certification, improved incident reporting requirements

ISSEP Takeaways

- FISMA = legal driver behind the RMF and all NIST pubs
- Requires agencies to categorize systems (FIPS 199) and apply minimum security requirements (FIPS 200)
- Continuous monitoring (SP 800-137) replaced "point-in-time certification" model
- Compliance measured not just by documentation, but by ongoing risk management
- ISSOs/ISSEs operate under FISMA authority when applying NIST/DoD standards

Crosslinks

- FIPS 199 & 200 → mandatory standards under FISMA for categorization and minimum security requirements
- SP 800-37 → RMF process implementing FISMA mandates
- SP 800-53 → control catalog supporting FISMA compliance
- OMB → reporting body for FISMA metrics
- CNSSI 1253 → overlays adapt FISMA/NIST requirements for NSS/DoD

✅ Exam Lens

Expect questions on:

- FISMA = law requiring federal agencies to secure IT systems
- Role of FISMA as the foundation for NIST RMF (800-37, 800-53, FIPS 199/200)
- Key mandates → risk-based security, annual reporting, NIST + OMB roles
- Continuous monitoring emphasis after 2014 modernization
- Relationship between FISMA → FIPS → NIST SPs

Laws & Mandates

Purpose

Defines the mandatory process for categorizing federal information systems by potential impact levels on confidentiality, integrity, and availability (CIA). Serves as the foundation for selecting security controls under FISMA.

Core Concepts

- Three Security Objectives → Confidentiality, Integrity, Availability
- Impact Levels → Low, Moderate, High (potential harm to operations, assets, individuals, or national security)
- System Categorization → highest value among CIA triad = overall system impact level
- Mandatory Standard → required for all federal systems under FISMA
- Drives Risk Mgmt → categorization results directly determine baseline security controls (SP 800-53)

ISSEP Takeaways

- FIPS 199 = starting point for RMF → used in Step 2: Categorize
- Must know CIA objectives and Low/Moderate/High impact definitions
- The "high water mark" principle → overall categorization = highest of any CIA rating
- ISSOs/ISSEs rely on categorization to determine control baselines and overlays
- Ties directly into mission/business risk (impact to operations, assets, individuals, nation)

Crosslinks

- FISMA → mandates use of FIPS 199 for categorization
- FIPS 200 → minimum security requirements linked to impact levels
- SP 800-60 → mapping of information types to impact values
- SP 800-37 (RMF) → Categorize step implements FIPS 199
- CNSSI 1253 → provides overlays for National Security Systems

✅ Exam Lens

Expect questions on:

- Purpose of FIPS 199 = categorize systems based on CIA impact
- The three security objectives (Confidentiality, Integrity, Availability)
- Impact levels (Low, Moderate, High) definitions
- High-water mark rule → highest rating = system's overall impact
- How categorization drives control baseline selection in RMF

Laws & Mandates

Purpose

Defines the minimum security requirements that federal information systems must meet to protect confidentiality, integrity, and availability (CIA). Works hand-in-hand with FIPS 199 to ensure categorization leads to enforceable safeguards.

Core Concepts

• Seventeen Security Areas → mapped directly to SP 800-53 families:
– Access Control, Awareness & Training, Audit & Accountability, Certification/Authorization, Configuration Mgmt, Contingency Planning, Identification & Authentication, Incident Response, Maintenance, Media Protection, Physical/Environmental Protection, Planning, Personnel Security, Risk Assessment, Systems & Services Acquisition, System/Comm Protection, System Integrity
• Impact-Driven → selected controls must match system impact level (Low, Moderate, High) from FIPS 199
• Mandatory Standard → applies to all federal systems under FISMA
• Baseline Creation → FIPS 200 requirements implemented using the SP 800-53 control catalog

ISSEP Takeaways

• FIPS 200 = minimum floor of protection; SP 800-53 = catalog of controls to meet it
• Used in RMF Step 2: Categorize → Step 3: Select
• ISSOs/ISSEs must ensure systems meet all 17 requirement areas appropriate to impact level
• Establishes "what must be addressed," while 800-53 provides the "how"
• Ensures categorization (FIPS 199) translates into baseline security requirements

Crosslinks

• FISMA → mandates FIPS 199/200 compliance
• FIPS 199 → provides impact level that drives 200's minimum requirements
• SP 800-37 (RMF) → Select step ensures requirements are implemented
• SP 800-53 → control catalog fulfilling FIPS 200 minimums
• CNSSI 1253 → overlays adapt FIPS 200 to NSS systems

✅ Exam Lens

Expect questions on:
• Purpose of FIPS 200 = minimum requirements for system security
• The 17 requirement areas (know categories, not full details)
• Relationship to FIPS 199 (categorization) and SP 800-53 (controls)
• How requirements scale with impact level (Low/Mod/High)
• Role of FIPS 200 in RMF Select step

Laws
& Mandates

Purpose

Provides guidance for mapping federal information and information systems to security categories defined in FIPS 199. Helps agencies identify the potential impact (Low, Moderate, High) for confidentiality, integrity, and availability based on information type.

Core Concepts

- Mapping Tables → extensive catalog of federal information types (e.g., HR data, financial data, intelligence) linked to recommended CIA impact levels
- Process →
  – Identify information type(s) used by a system
  – Map to recommended CIA impact levels
  – Validate with mission/business context
  – Apply high-water mark rule from FIPS 199
- Flexibility → recommended impact levels may be tailored based on organizational risk tolerance
- Purpose → ensures consistent and defendable categorizations across federal agencies

ISSEP Takeaways

- 800-60 = practical companion to FIPS 199
- Provides "how-to" mappings for assigning CIA impact to real-world info types
- Ensures categorization decisions are consistent across agencies
- ISSOs/ISSEs must validate mappings against mission/business needs, not blindly adopt tables
- Outputs directly feed RMF Categorize step

Crosslinks

- FIPS 199 → categorization standard; 800-60 provides mappings to apply it
- FIPS 200 → defines minimum requirements once categorization is set
- SP 800-37 (RMF) → 800-60 supports Step 2: Categorize
- CNSSI 1253 → overlays adapt categorization for NSS
- SP 800-39 & 30 → risk management context and assessment data inform final categorization decisions

✅ Exam Lens

Expect questions on:

- 800-60 = mapping guide for categorization (how to apply FIPS 199)
- Relationship between FIPS 199 → 800-60 → FIPS 200/SP 800-53
- High-water mark principle
- Impact values are recommendations → agencies can adjust with justification
- Role of 800-60 in RMF Categorize step

ISSEP CBK

Purpose

Defines the knowledge framework and domains for the ISSEP concentration of the CISSP. Provides a standardized body of knowledge for security engineers integrating security into systems engineering, risk management, and federal standards (esp. NIST & DoD).

Core Concepts

• Domains (5 Total) →

1. **Systems Security Engineering Foundations** – principles, processes, trustworthiness concepts
2. **Risk Management** – RMF, risk assessment, mitigation, and decision-making
3. **Security Planning & Engineering** – requirements, architectures, and secure system trade-offs
4. **Systems Implementation, Verification & Validation** – controls, assessment, test, and evaluation (C&A/A&A)
5. **Secure Operations, Change Management, & Disposal** – sustainment, monitoring, and decommissioning
   • Engineering Approach → ties directly to NIST SP 800-160 and ISO/IEC/IEEE 15288
   • Policy & Guidance Alignment → heavy reliance on NIST RMF (SP 800-37/53), FISMA, CNSSI 1253, DoDI 8500/8510, JSIG, DAAPM

ISSEP Takeaways

• CBK = the scope of ISSEP exam content → what ISC² expects engineers to know
• Exam emphasizes federal/NIST/DoD frameworks + systems engineering integration
• ISSEP = "RMF + Engineering + Risk Mgmt" lens
• Important for ISSOs/ISSEs → validates you can engineer security into the system lifecycle while ensuring compliance
• Domains map closely to system life cycle phases

Crosslinks

• SP 800-160 Vol. 1 & 2 → security engineering + resiliency
• SP 800-37/39/30/34/53/137 → RMF, risk, controls, continuity, monitoring
• ISO/IEC/IEEE 15288 & 42010 → international engineering/architecture baselines
• JSIG / DAAPM → specialized A&A overlays for SAP/IC
• DoDI 8500.01 / 8510.01 → DoD cybersecurity policy + RMF execution

✅ Exam Lens

Expect questions on:
• The five ISSEP domains and their focus areas
• How ISSEP CBK ties into RMF and systems engineering frameworks
• Connection between NIST pubs and ISSEP exam expectations
• The role of ISSEP as a bridge between security policy and engineering practice
• Difference between CISSP (broad) and ISSEP (deep in RMF/engineering)